

Security+ 2.4 · Password Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Password Attacks (7:15) · [vídeo original](#) · [YouTube](#)

Password attack: password spraying (UMA senha comum MUITOS usuários — evita lockout); credential stuffing (senhas VAZADAS reusadas); brute force (todas as combinações — rápido mas detectável); dictionary (lista de palavras); rainbow table (hash pré-computados — MORTO pelo SALTING). Defesa: MFA, manager de senha, lockout, salt + argon2/bcrypt, monitorar login anômalo.

Highlights que a prova cobra

- Password spraying: 1 senha fraca contra muitos usuários (discreto)
- Brute force = tentar tudo; dictionary = lista de palavras
- Rainbow table = hash pré-computada — MORTA pelo SALTING
- Reusa de senha vazada em outros sites = credential stuffing

Dicas de prova

- 'single weak password tried against many accounts' = password spraying
- 'pre-computed hash table' = rainbow table (defesa: salting)

Cenário clássico: Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):
 - A) Credential stuffing
 - B) Força bruta pura
 - C) Rainbow table
 - D) Vishing

2. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?

- A)** Senha + PIN
- B)** Senha + Token físico
- C)** Dois tipos de biometria
- D)** Pergunta de segurança + Senha

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Password spraying: 1 senha fraca contra muitos usuários (discreto)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Password spraying: 1 senha fraca contra muitos usuários (discreto)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Brute force = tentar tudo; dictionary = lista de palavras'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Brute force = tentar tudo; dictionary = lista de palavras...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Rainbow table = hash pré-computada — MORTA pelo SALTING'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Rainbow table = hash pré-computada — MORTA pelo SALTING...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Reusa de senha vazada em outros sites = credential stuffing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Reusa de senha vazada em outros sites = credential stuffing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'single weak password tried against many accounts' = password spraying'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'single weak password tried against many accounts' = password spraying...

9. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'pre-computed hash table' = rainbow table (defesa: salting)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'pre-computed hash table' = rainbow table (defesa: salting)...

10. Cenário corporativo (Password Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio...

GABARITO COMENTADO

- 1) A — Credential stuffing.** Credential stuffing = reusar credenciais vazadas em outros serviços. Força bruta testa combinações; dictionary usa lista de palavras comuns.
- 2) B — Senha + Token físico.** MFA verdadeira combina fatores de categorias diferentes: algo que você sabe (senha) + algo que você tem (token físico). Múltiplos fatores da mesma categoria não constituem MFA.
- 3) A — Hash com salt (ex: bcrypt).** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).
- 4) B — Implementar a solução correspondente: Password spraying: 1 senha fraca contra mu.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Password spraying: 1 senha fraca contra muitos usuários (discreto). As demais alternativas configuram violações grav
- 5) B — Implementar a solução correspondente: Brute force = tentar tudo; dictionary = li.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Brute force = tentar tudo; dictionary = lista de palavras. As demais alternativas configuram violações graves de con
- 6) C — Implementar a solução correspondente: Rainbow table = hash pré-computada — MORTA.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Rainbow table = hash pré-computada — MORTA pelo SALTING. As demais alternativas configuram violações graves de confo
- 7) B — Implementar a solução correspondente: Reusa de senha vazada em outros sites = cr.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Reusa de senha vazada em outros sites = credential stuffing. As demais alternativas configuram violações graves de c
- 8) D — Implementar a solução correspondente: 'single weak password tried against many a.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): 'single weak password tried against many accounts' = password spraying. As demais alternativas configuram violações
- 9) D — Implementar a solução correspondente: 'pre-computed hash table' = rainbow table .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): 'pre-computed hash table' = rainbow table (defesa: salting). As demais alternativas configuram violações graves de c
- 10) D — Implementar a solução correspondente: Cenário: 'atacante usa a senha Password123.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Password Attacks): Cenário: 'atacante usa a senha Password123! em todos os usuários do domínio, evitando lockout' = password spraying..

